AI GOVERNANCE LAB · ADDENDUM

Round five

Fourteen more cases, written after I audited the lab: vendor “read access”, search that ignores file permissions, movers, access reviews, and the log. With the controls mapped to ISO 27001, NIST 800-53, PCI DSS and HIPAA.

Roshan Trivedi
24 October 2026 · roshantrivedi.co.in/ai-governance-lab

READ THIS FIRST

Why there is an addendum

Edition one of “Does AI Governance Hold?” has 59 lab cases and nine assistant tests. After I audited it from an identity-governance view, I found gaps I had not tested.

The biggest was the sentence vendors use: “our AI only needs read access on your domain”. The lab did not test it. So I wrote the expected results for 14 new cases and committed them to the lab repository at 23:38 on 24 October 2026. Then I wrote the code and ran them.

All 14 came out as I guessed. Please read that carefully. It shows that the controls I added do what I built them to do. It does not show they are enough, because I wrote both the guess and the code. One case, I13, crashed on the first run because my test did not let time pass before issuing a new token. I fixed the test, not the lab, and kept both result files.

Everything here is made up: a lender called Kaveri Finance, and numbers that follow real formats (Aadhaar numbers pass the Verhoeff check, card numbers pass Luhn, PANs follow the format only). The numbers are random, so one could match a real person’s by chance. None came from a real record.

PART ONE

The 14 cases

Track V: Vendor and third-party AI access

V1 A vendor AI app asks for read access to the whole domain: all mail and all files

A vendor says its AI needs “read access on your domain”. The app asks for all mail and all files, everywhere.

> STEP The app InboxPilot AI (made up) asks for two scopes: read all mail and read all files.

> STOPPED The consent check sees tenant-wide scopes and holds the request: “narrow it to named folders and name a data owner”.

> WORKS Nothing is granted. No grant is on file.

Result: Held. Nothing granted.

Why it matters: This is the sentence a buyer hears in a sales call. The control is a rule that the answer is not yes until the scope is narrow and someone owns the data.

My guess: held · What came out: held

V2 The same vendor, narrowed to one shared folder, with a named data owner

The same kind of app, narrowed to one public folder, with a named data owner.

> STEP FAQ Helper AI asks to read only /Shared/Support FAQ, and names a staff member as data owner.

> WORKS Granted for 90 days, with the owner and the expiry written to the log.

> WORKS Reading the FAQ folder works on day 0. Reading the HR salary folder does not.

> WORKS On day 91 even the FAQ folder stops working. Someone has to ask again.

Result: Granted for 90 days, one folder, one owner.

Why it matters: Read access is fine when it is small, owned and ends by itself. The expiry is what makes someone look again.

My guess: granted with expiry · What came out: granted with expiry

V3 A consent review 100 days later: one grant expired, one app never used

A consent review later: which grants ended and which apps nobody uses.

> STEP Two apps are granted a folder on day 0. One is used on day 10. The other is never used.

> WORKS On day 40 the review flags the idle app as unused.

> WORKS On day 100 both grants have expired and the review revokes them. The app that was used no longer works either.

Result: Idle app flagged on day 40, both grants expired by day 100.

Why it matters: Most firms are good at saying yes once. This case checks that access has a second look built in.

My guess: expired and flagged · What came out: expired and flagged

V4 A vendor AI app that processes in a region outside India asks to read folders with personal data

A vendor AI app that processes data outside India asks to read the folder of loan files, which hold personal data.

> STEP LoanReader AI asks to read /Customers/Loan files and says it processes in the US.

> STOPPED Held: the app processes abroad and the folder holds personal data, the same rule the gateway applies to a model call.

> WORKS The same request with processing in India is granted for 90 days, so the rule is about the region and the data, not the vendor.

Result: Held while it processes abroad.

Why it matters: “Read only” still moves the data to wherever the vendor runs. The region is part of the access decision.

My guess: held · What came out: held

Track R: Retrieval and document permissions

R1 An agent searching company files for one employee: search that ignores document permissions versus search that checks them

An AI agent answers a support-team member by searching company files. Does the search obey the person's file permissions?

> **STEP** The person is on the Support team. They ask the agent about “salary review”.

> **GETS THROUGH** A plain search returns the HR salary file and two other team files the person cannot open.

> **WORKS** A search that checks the person's permissions returns nothing.

Result: A plain search leaks three files. A permission-checked search leaks none.

Why it matters: This is the “read access on your domain” problem in one test: the agent can read everything, so it can quote everything. The agent must be limited to what the asker may see.

My guess: leaks · What came out: leaks

R2 A person moves department, but the search index still holds their old permissions

A person moves from HR to Support, but the search index still holds a copy of their old permissions.

> **STEP** Before the move the HR person finds the salary file. That is correct.

> **GETS THROUGH** After the move, the index still shows the salary file to them, because its copy of permissions is old.

> **WORKS** Checking the directory at the moment of the question returns nothing. So does the index after a refresh.

Result: A stale permission copy leaks until it is refreshed. A live check does not.

Why it matters: Joiner, mover, leaver applies to search indexes too. A cached permission is an old decision.

My guess: leaks until refresh · What came out: leaks until refresh

Track I: Agent identity, more cases

I13 An agent's sponsor moves to another department

An agent's sponsor moves to another department.

> STEP The agent has a valid token. The sponsor changes team.

> STOPPED The agent is paused and its old token stops working. A new token is refused.

> STOPPED The sponsor cannot confirm their own agent.

> WORKS A different approver re-confirms it. A new token works. The old token stays dead.

Result: Held until a new approver re-confirms it.

Why it matters: Access that made sense in the old job is a mover problem. The agent must not quietly follow its sponsor into a new role.

My guess: held until recertified · What came out: held until recertified

I14 An access review of agents: one scope never used, one agent never reviewed in 30 days

An access review of agents: scopes never used, and agents nobody has reviewed.

> STEP Agent A holds two scopes and uses one. Agent B is never reviewed. Agent A is re-confirmed on day 20.

> WORKS On day 31 the review flags A's unused scope (email.draft).

> STOPPED Agent B has gone 30 days without review and is switched off.

Result: Unused scope flagged. The unreviewed agent was switched off.

Why it matters: Recertification is the control auditors ask about first. For agents it should flag what is held but never used.

My guess: unused scope flagged and lapsed · What came out: unused scope flagged and lapsed

I15 An agent is registered with read on HR files and the right to send email (a toxic combination)

An agent is registered with read access to HR files and the right to send email: a combination that can send HR data out.

> STEP Registration asks for hr.read and email.send in one agent.

> STOPPED Refused as a toxic combination.

> WORKS The same agent with email.draft instead of email.send registers, so a person has to send it.

Result: Refused at registration.

Why it matters: Separation of duties is not only for people. Two harmless permissions can add up to a path out.

My guess: refused · What came out: refused

I16 A token issued for one service is shown to a different service

A token issued for one service is shown to a different service.

> STEP The agent gets a token made for crm-api.

> WORKS crm-api accepts it.

> STOPPED hr-api rejects it: the token was not made for that service.

Result: Refused by the wrong service.

Why it matters: A token that works everywhere is a skeleton key. Naming the service it is for limits the damage if it leaks.

My guess: refused · What came out: refused

I17 A person who delegated to an agent leaves while the agent's token is still valid

A person who delegated work to an agent leaves while the agent's token is still valid.

> STEP The agent holds a token to act for a support employee. It works.

> STEP The employee leaves.

> STOPPED The token stops working at once, even though it has minutes left. The agent itself stays active for its other work.

Result: Token revoked when the person left.

Why it matters: Delegation should end when the delegator does. Otherwise a leaver's access lives on inside a bot.

My guess: revoked · What came out: revoked

I18 A privileged-access approval by someone whose last sign-in check was 45 minutes ago, then 3 minutes ago

A privileged-access approval from someone whose last sign-in check was a while ago.

> STEP An approver is asked to approve a privileged restart. Their last sign-in check was 45 minutes ago.

> STOPPED Refused: the check must be within 10 minutes.

> WORKS With a check 3 minutes old, the approval is accepted.

Result: Stale check refused, fresh check accepted.

Why it matters: An approval is only as good as the proof of who approved. Step-up sign-in belongs on exactly the approvals that matter.

My guess: stale refused fresh accepted · What came out: stale refused fresh accepted

Track E: Audit evidence, more cases

E15 A blocked request contained an Aadhaar number: does the decision log hold the number?

A blocked request that contained a customer's personal data. Does the decision log keep the data?

> STEP A prompt with a made-up Aadhaar number, card number, PAN and name goes to a use that is not approved for personal data.

> STOPPED The gateway blocks it.

> WORKS The log holds the decision and the reason. The Aadhaar, card, PAN and name do not appear in any log line.

Result: The log is clean of personal data.

Why it matters: A log that copies the prompt becomes a second store of personal data, with its own retention and erasure problems.

My guess: clean · What came out: clean

E16 A log line is added with a date earlier than the line before it

A log line is written with a date earlier than the line before it.

> STEP Two normal requests are logged. Then the clock goes back two days and a third request is logged.

> GETS THROUGH The hash chain still checks out. It proves the order and the content, not that the dates make sense.

> STEP Only a separate check on dates, against a trusted clock, notices the line dated earlier than the one before it.

Result: The chain accepts backdating. A date check would catch it.

Why it matters: Auditors rely on log dates. The chain protects against edits, not against a wrong clock.

My guess: chain accepts backdating · What came out: chain accepts backdating

PART TWO

Controls and where they sit

The first sixteen controls were mapped to AI frameworks in edition one. This table shows the same controls against ISO/IEC 27001:2022 Annex A, NIST SP 800-53, PCI DSS 4.0 and HIPAA, plus seven new controls (C17 to C23). A dash means I did not map it. It is my own reading, not legal advice and not a certification. Check each number against your own copy of the standard.

CONTROL	ISO 27001	NIST 800-53	PCI DSS 4.0	HIPAA
C1 AI use register with a named owner for every use	A.5.9	CM-8	12.5.1	-
C2 Approval by someone other than the owner; high-risk uses need an impact assessment and a person's sign-off	A.5.3, A.5.4	AC-5, CA-6	-	-
C3 Approvals expire; changes to model version or risk tier force a new review	A.8.32	CM-3	-	-
C4 Personal and confidential data only to models approved for it; cross-border held for review	A.5.34, A.8.12	AC-4	-	164.312(e)(1)
C5 Guardrail masks secrets and Indian personal data before a model sees them, and flags injection	A.8.12	SI-10	-	-
C6 Kill switch: one use or one agent stopped at once	A.5.26	IR-4	-	-
C7 Tamper-evident decision log	A.8.15	AU-2, AU-3, AU-9	10.2, 10.3	164.312(b)
C8 AI bill of materials for every use	A.5.21	SR-4	6.3.2	-
C9 Agents have their own identity, a human sponsor, short-lived tokens and only their scopes	A.5.16, A.5.18	AC-2, IA-4, IA-5	8.2.1, 8.6	164.308(a)(3)
C10 Agents acting for a person never exceed that person; agent-to-agent messages are signed	A.5.15, A.8.3	AC-3, AC-6	7.2	-
C11 Privileged actions need a just-in-time grant from someone else, with a recorded session	A.8.2	AC-6	7.2, 8.4	164.312(a)(1)
C12 Incidents: timeline from detection to closure, and a report inside 6 hours	A.5.24, A.5.26	IR-4, IR-6	12.10	164.308(a)(6)
C17 Vendor and third-party AI access is narrow, owned, time-limited and reviewed (V1, V2, V3, V4)	A.5.15, A.5.18, A.5.19, A.5.20	AC-3, AC-6, SA-9, CA-3	7.2, 12.8	164.308(b)
C18 AI search and retrieval obey the asker's live permissions (R1, R2)	A.5.15, A.5.18, A.8.3	AC-3, AC-6	7.2	164.312(a)(1)
C19 Mover and leaver: an agent is re-confirmed when its sponsor moves, and tokens stop when a person leaves (I6, I13, I17)	A.5.16, A.5.18, A.6.5	AC-2, PS-4, PS-5	8.2.5, 8.2.6	164.308(a)(3)(ii)(C)
C20 Periodic access review of agents: unused scopes flagged, unreviewed agents switched off (I10, I14)	A.5.18	AC-2	7.2.4	164.308(a)(4)(ii)(C)
C21 Separation of duties: no toxic combinations, and step-up sign-in for privileged approvals (I7, I15, I18)	A.5.3, A.8.2, A.8.5	AC-5, AC-6, IA-2	8.4, 7.2	164.312(d)

CONTROL	ISO 27001	NIST 800-53	PCI DSS 4.0	HIPAA
C22 Tokens are made for one service and end with the person (I3, I16, I17)	A.5.17, A.8.5	IA-5, SC-23, AC-12	8.3, 8.6	164.312(d)
C23 Logs hold no personal data, and their dates can be trusted (E5, E15, E16)	A.5.34, A.8.15, A.8.17	AU-3, AU-8, AU-9	10.2, 10.3, 10.6	164.312(b)

For the Indian rules on the new controls: DPDP Act section 8 (safeguards and processors) and section 16 (transfers), the RBI master direction on outsourcing of IT services, and the CERT-In directions on logs.

PART THREE

What this still does not cover

- These cases test small models of the controls (a consent register, a search with a permission list, an identity service). They do not connect to a real mail system, directory or cloud tenant.
- Not tested: more than one hop of delegation between agents, real single sign-on and provisioning protocols, binding a token to the caller’s key, real-time revocation signals between systems, and erasing one person from a hash-chained log.
- The next big step on the vendor question is a test against a real sandbox tenant, with a real consent screen and a real directory.
- If you can see a weak test, please tell me. I would rather learn it from you than from an incident.

Everything is free: roshantrivedi.co.in/ai-governance-lab